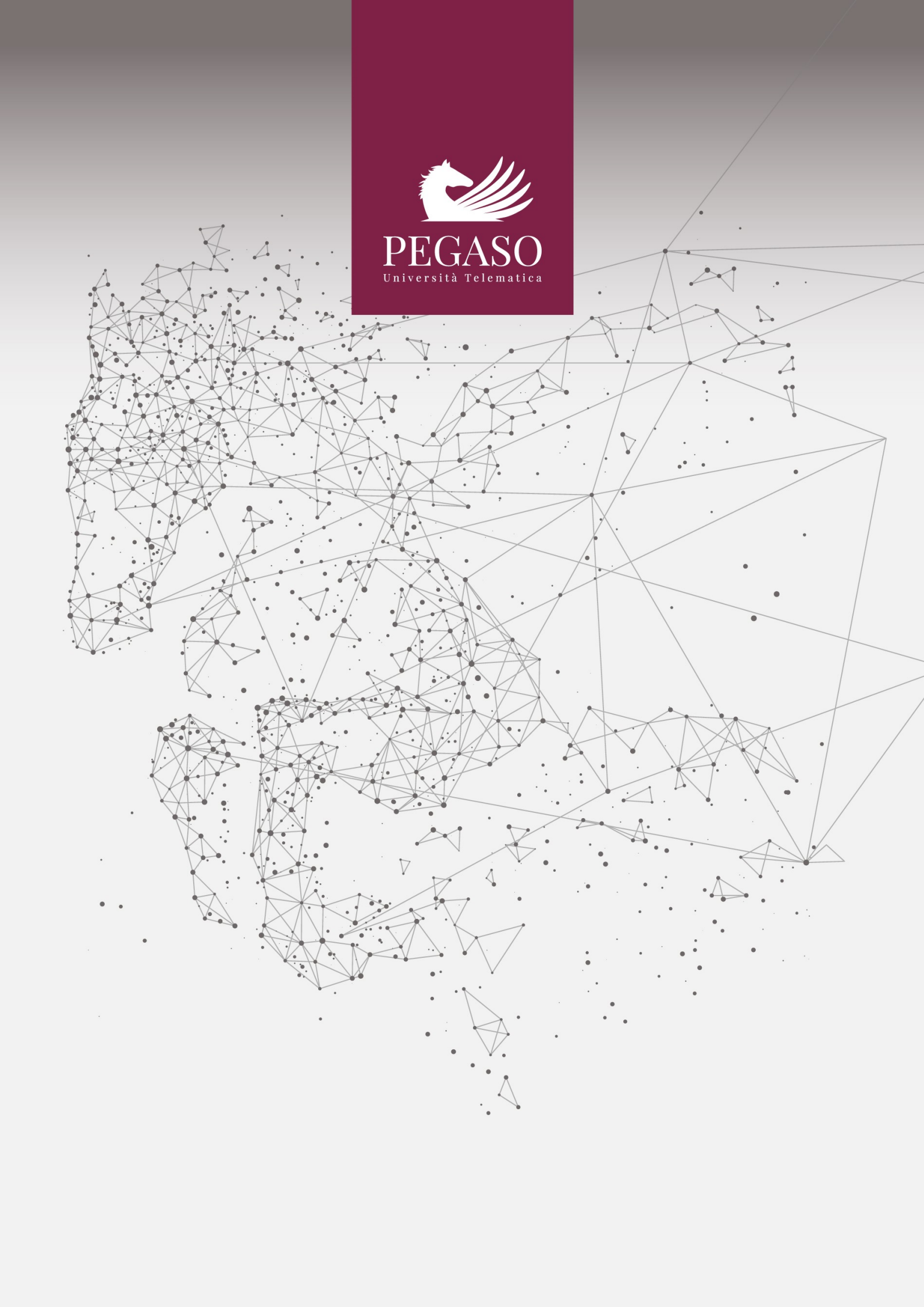

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. LE NOVITÀ 3
2. IL DATA PROTECTION OFFICER 7
3. IL REGIME SANZIONATORIO 10
BIBLIOGRAFIA 12

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Le novità

Il Regolamento UE 2015/679 (di seguito denominato come "GDPR") è entrato in vigore il 4 maggio 2016 e diventerà definitivamente applicabile in via diretta in tutti i Paesi dell'Unione Europea a partire dal 25 maggio 2018[1], quando dovrà essere garantito il perfetto allineamento fra la normativa nazionale in materia di protezione dati e le disposizioni del Regolamento.

Una delle maggiori novità del GDPR è data dalla sua applicazione territoriale, che vede un'estensione rispetto alla direttiva 95/46 CE.

L'ambito di applicazione territoriale è disciplinato, anche se non esaurito del tutto, dall'articolo 3 GDPR che prevede che il regolamento si applica:

- al trattamento dei dati personali effettuato nell'ambito delle attività di uno stabilimento da parte di un titolare del trattamento o di un responsabile del trattamento nell'Unione, indipendentemente dal fatto che il trattamento sia effettuato o meno nell'Unione;
- al trattamento dei dati personali di interessati che si trovano nell'Unione, effettuato da un titolare del trattamento o da un responsabile del trattamento che non è stabilito nell'Unione, quando le attività di trattamento riguardano:

a) l'offerta di beni o la prestazione di servizi ai suddetti interessati nell'Unione, indipendentemente dall'obbligatorietà di un pagamento dell'interessato; oppure

b) il monitoraggio del loro comportamento nella misura in cui tale comportamento ha luogo all'interno dell'Unione.

- al trattamento dei dati personali effettuato da un titolare del trattamento che non è stabilito nell'Unione, ma in un luogo soggetto al diritto di uno Stato membro in virtù del diritto internazionale pubblico.

Il GDPR per l'applicazione territoriale utilizza dei criteri geografici, logici e di destinazione in relazione alle attività del titolare o del responsabile del trattamento.

[1] Dalla stessa data sarà abrogata la Direttiva 95/46/CE che attualmente disciplina a livello europeo il trattamento dei dati.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Inoltre, al variare delle tipologie di trattamento varia l'applicazione territoriale del GDPR, quindi può accadere che per il medesimo titolare o responsabile del trattamento possono variare i criteri di applicazione territoriale a seconda del trattamento preso in considerazione.

Quindi e ricapitolando, si applica il GDPR se:

- lo stabilimento è nell'Unione Europea e il trattamento viene effettuato da questo stabilimento nell'ambito delle sue attività;
- lo stabilimento è considerato al di fuori dell'Unione Europea, ma il trattamento viene effettuato nell'ambito delle attività di offerta di beni o servizi agli interessati nell'Unione Europea oppure attività di monitoraggio di comportamenti di questi nell'Unione Europea; inoltre, stante il tenore letterale della norma i soggetti interessati devono trovarsi anche in via non esclusiva nell'Unione[2].

Uno dei principi fondamentali per la *compliance* con il GDPR è il principio di responsabilizzazione o *accountability,* che consiste innanzitutto nel rispetto dei principi di trattamento di cui all'art. 5 comma 1 GDPR[3].

Ne consegue la necessità che il titolare sappia dimostrare il rispetto dei relativi principi.

In particolare, il Considerando 74 precisa che è opportuno stabilire la responsabilità generale del titolare del trattamento per qualsiasi trattamento di dati personali che quest'ultimo abbia effettuato direttamente o che altri abbiano effettuato per suo conto.

---

[2] L. BOLOGNINI, E. PELINO e C. BISTOLFI, *il regolamento privacy europeo*, Giuffrè, Milano, 2016, p. 3.

[3] I dati personali sono:

a) trattati in modo lecito, corretto e trasparente nei confronti dell'interessato («liceità, correttezza e trasparenza»);
b) raccolti per finalità determinate, esplicite e legittime, e successivamente trattati in modo che non sia incompatibile con tali finalità; un ulteriore trattamento dei dati personali a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici non è, conformemente all'articolo 89, paragrafo 1, considerato incompatibile con le finalità iniziali («limitazione della finalità»);
c) adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità per le quali sono trattati («minimizzazione dei dati»);
d) esatti e, se necessario, aggiornati; devono essere adottate tutte le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti rispetto alle finalità per le quali sono trattati («esattezza»);
e) conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati; i dati personali possono essere conservati per periodi più lunghi a condizione che siano trattati esclusivamente a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici, conformemente all'articolo 89, paragrafo 1, fatta salva l'attuazione di misure tecniche e organizzative adeguate richieste dal presente regolamento a tutela dei diritti e delle libertà dell'interessato («limitazione della conservazione»);
f) trattati in maniera da garantire un'adeguata sicurezza dei dati personali, compresa la protezione, mediante misure tecniche e organizzative adeguate, da trattamenti non autorizzati o illeciti e dalla perdita, dalla distruzione o dal danno accidentali («integrità e riservatezza»).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Ancora più in particolare, il titolare del trattamento dovrebbe essere tenuto a mettere in atto "*misure adeguate ed efficaci* ed essere in grado *di dimostrare la conformità delle attività di trattamento con il presente regolamento*, compresa *l'efficacia delle misure*".

Tali misure dovrebbero tener conto della natura, dell'ambito di applicazione, del contesto e delle finalità del trattamento, nonché del rischio per i diritti e le libertà delle persone fisiche.

A tali *misure adeguate ed efficaci* troviamo un riferimento nell'articolo 24 comma 1. GDPR, il quale precisa che il titolare del trattamento mette in atto misure tecniche e organizzative adeguate per garantire, ed essere in grado di dimostrare, che il trattamento è effettuato conformemente al presente regolamento.

Dette misure sono riesaminate e aggiornate qualora necessario.

Quindi, il titolare ha un onere oltre di adottare le misure adeguate ed efficaci, di dimostrarne l'efficacia oltre che la conformità delle attività del trattamento alle disposizioni del GDPR.

Gli altri due principi fondamentali che il titolare del trattamento deve rispettare per garantire la *compliance* al GDPR sono i principi di *privacy by design* e di *privacy by default*, che sono esplicitati dal Considerando 78 del GDPR.

La tutela dei diritti e delle libertà delle persone fisiche relativamente al trattamento dei dati personali richiede l'adozione di misure tecniche e organizzative adeguate per garantire il rispetto delle disposizioni del presente regolamento.

Al fine di dimostrare la conformità con il GDPR, il titolare del trattamento dovrebbe adottare politiche interne e attuare misure che soddisfino in particolare i principi della protezione dei dati fin dalla progettazione (*privacy by design*) e della protezione dei dati di default (*privacy by default*).

Tali misure potrebbero consistere, tra l'altro, nel ridurre al minimo il trattamento dei dati personali e offrire trasparenza per quanto riguarda le funzioni e il trattamento di dati personali, nonché consentire all'interessato di controllare il trattamento dei dati e consentire al titolare del trattamento di creare e migliorare caratteristiche di sicurezza.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

In fase di sviluppo, progettazione, selezione e utilizzo di applicazioni, servizi e prodotti basati sul trattamento di dati personali o che trattano dati personali per svolgere le loro funzioni, i produttori dei prodotti, dei servizi e delle applicazioni dovrebbero essere incoraggiati a tenere conto del diritto alla protezione dei dati allorché sviluppano e progettano tali prodotti, servizi e applicazioni e, tenuto debito conto dello stato dell'arte, a far sì che i titolari del trattamento e i responsabili del trattamento possano adempiere ai loro obblighi di protezione dei dati.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Il Data Protection Officer

Ai sensi dell'articolo 37 GDPR il titolare del trattamento e il responsabile del trattamento designano sistematicamente un responsabile della protezione dei dati ("Data Protection Officer" o "DPO") ogniqualvolta:

- il trattamento è effettuato da un'autorità pubblica o da un organismo pubblico, eccettuate le autorità giurisdizionali quando esercitano le loro funzioni giurisdizionali. Secondo le *Guidelines On Data Protection Officer* del Working Party Article 29 ("WP29"), la nozione di autorità pubblica o organismo pubblico è demandata alla legge dei singoli stati membri[4]; inoltre, la designazione del DPO nonostante non sia obbligatoria è consigliata per le società concessionarie di pubblici servizi[5];
- le *attività principali* (cd. *core activities*) del titolare del trattamento o del responsabile del trattamento consistono in trattamenti che, per loro natura, ambito di applicazione e/o finalità, richiedono il monitoraggio regolare e sistematico degli interessati su *larga scala*;
- le *attività principali* del titolare del trattamento o del responsabile del trattamento consistono nel trattamento, su *larga scala*, di categorie particolari di dati personali o di dati relativi a condanne penali e a reati[6].

Per attività principali il Considerando 97 specifica che "*nel settore privato le attività principali del titolare del trattamento riguardano le sue attività primarie ed esulano dal trattamento dei dati personali come attività accessoria*".

Il GDPR non dà nessuna definizione di "larga scala", anche se un qualche parametro lo fornisce il Considerando 91 (relativo alla predisposizione del *Data Privacy Impact Assesement* o valutazione d'impatto sulla protezione dei dati) dove parla di "*trattamenti su larga scala, che*

[4] Guidelines 2 comma 1: "*the GDPR does not define what constitutes a 'public authority or body'. The WP29 considers that such a notion is to be determined under national law*".
[5] Si dispone che "*even though there is no obligation in such cases, the WP29 recommends, as a good practice, that private organisations carrying out public tasks or exercising public authority designate a DPO*".
[6] Sono i "*dati personali che rivelino l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, o l'appartenenza sindacale, nonché trattare dati genetici, dati biometrici intesi a identificare in modo univoco una persona fisica, dati relativi alla salute o alla vita sessuale o all'orientamento sessuale della persona*" (art 9. GDPR).

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

mirano al trattamento di una notevole quantità di dati personali a livello regionale, nazionale o sovranazionale e che potrebbero incidere su un vasto numero di interessati".

Nelle *Guidelines* il WP29[7] ha precisato che devono essere prese in considerazioni alcuni fattori per determinare se il trattamento è effettuato su larga scala o meno.

In particolare:

- il numero dei soggetti interessati, siano essi un numero specifico o una porzione della popolazione presa in considerazione;
- il volume dei dati o il *range* dei diversi dati che sono trattati;
- la durata o la persistenza del trattamento;
- l'estensione geografica dell'attività di trattamento.

Per quanto riguarda le attività del DPO innanzitutto "Il titolare del trattamento e il responsabile del trattamento si assicurano che il responsabile della protezione dei dati sia tempestivamente e adeguatamente coinvolto in tutte le questioni riguardanti la protezione dei dati personali." (art. 38.1. GDPR) ed inoltre il Data Protection Officer, ai sensi dell'articolo 39 GDPR, è incaricato almeno dei seguenti compiti:

- informare e fornire consulenza al titolare del trattamento o al responsabile del trattamento nonché ai dipendenti che eseguono il trattamento in merito agli obblighi derivanti dal GDPR nonché da altre disposizioni dell'Unione o degli Stati membri relative alla protezione dei dati;
- sorvegliare l'osservanza del GDPR, di altre disposizioni dell'Unione o degli Stati Membri relative alla protezione dei dati nonché delle politiche del titolare del trattamento o del responsabile del trattamento in materia di protezione dei dati personali, compresi

[7] Sono previsti inoltre alcuni esempi, dacché "*examples of large-scale processing include:*
- *processing of patient data in the regular course of business by a hospital;*
- *processing of travel data of individuals using a city's public transport system (e.g. tracking via travel cards);*
- *processing of real time geo-location data of customers of an international fast food chain for statistical purposes by a processor specialised in providing these services;*
- *processing of customer data in the regular course of business by an insurance company or a bank;*
- *processing of personal data for behavioural advertising by a search engine;*
- *processing of data (content, traffic, location) by telephone or internet service providers.*

Examples that do not constitute large-scale processing include:
- *processing of patient data by an individual physician;*
- *processing of personal data relating to criminal convictions and offences by an individual lawyer*".

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

l'attribuzione delle responsabilità, la sensibilizzazione e la formazione del personale che partecipa ai trattamenti e alle connesse attività di controllo;

- fornire, se richiesto, un parere in merito alla valutazione d'impatto sulla protezione dei dati e sorvegliarne lo svolgimento;
- cooperare con l'autorità di controllo; e
- fungere da punto di contatto per l'autorità di controllo per questioni connesse al trattamento, tra cui la consultazione preventiva a seguito della valutazione d'impatto sulla protezione dei dati personali, ed effettuare, se del caso, consultazioni relativamente a qualunque altra questione.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Il regime sanzionatorio

La Direttiva CE 95/46 non specificava né la tipologia né l'entità delle sanzioni, essendo rimesso ai singoli stati membri se sanzionare le violazioni penalmente e/o a livello amministrativo.

Il GDPR invece, prevede sia le violazioni passibili di sanzioni amministrative che i relativi importi, mentre per le sanzioni non amministrative viene lasciato spazio di manovra agli Stati Membri[8].

Il Considerando 148 del GDPR stabilisce che per rafforzare il rispetto delle norme del GDPR, dovrebbero essere imposte sanzioni, comprese[9] sanzioni amministrative pecuniarie per violazione del regolamento, in aggiunta o in sostituzione di misure appropriate imposte dall'autorità di controllo (cd. *Data Protection Autorithy* o DPA) ai sensi del GDPR stesso.

Ogni DPA (in Italia il Garante per la protezione dei dati personali) deve garantire, in ogni singolo caso, che la sanzione sia effettiva, proporzionata e dissuasiva, secondo i seguenti parametri:

- la natura, la gravità e la durata della violazione tenendo in considerazione la natura, l'oggetto o a finalità del trattamento in questione nonché il numero di interessati lesi dal danno e il livello del danno da essi subito;
- il carattere doloso o colposo della violazione;
- le misure adottate dal titolare del trattamento o dal responsabile del trattamento per attenuare il danno subito dagli interessati;
- il grado di responsabilità del titolare del trattamento o del responsabile del trattamento tenendo conto delle misure tecniche e organizzative da essi messe in atto;

[8] A livello penale, il trattato sul funzionamento dell'unione europea consente solo norme minime di indirizzo *"Allorché il ravvicinamento delle disposizioni legislative e regolamentari degli Stati membri in materia penale si rivela indispensabile per garantire l'attuazione efficace di una politica dell'Unione in un settore che è stato oggetto di misure di armonizzazione, norme minime relative alla definizione dei reati e delle sanzioni nel settore in questione possono essere stabilite tramite direttive. Tali direttive sono adottate secondo la stessa procedura legislativa ordinaria o speciale utilizzata per l'adozione delle misure di armonizzazione in questione, fatto salvo l'articolo 76." (art. 83.2. TFUE).*

[9] *Possono essere presenti quindi anche sanzioni amministrative non pecuniarie.*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- eventuali precedenti violazioni pertinenti commesse dal titolare del trattamento o dal responsabile del trattamento;
- il grado di cooperazione con l'autorità di controllo al fine di porre rimedio alla violazione e attenuarne i possibili effetti negativi;
- le categorie di dati personali interessate dalla violazione;
- la maniera in cui l'autorità di controllo ha preso conoscenza della violazione, in particolare se e in che misura il titolare del trattamento o il responsabile del trattamento ha notificato la violazione;
- qualora siano stati precedentemente disposti provvedimenti da parte della DPA;
- l'adesione ai codici di condotta approvati o ai meccanismi di certificazione approvati;
- eventuali altri fattori aggravanti o attenuanti applicabili alle circostanze del caso, ad esempio i benefici finanziari conseguiti o le perdite evitate, direttamente o indirettamente, quale conseguenza della violazione.

Per quanto riguarda l'ammontare delle sanzioni amministrazioni, sono previste due fasce: la prima ha come massimo edittale l'importo di 10 milioni di euro o per le imprese, fino al 2 % del fatturato mondiale totale annuo dell'esercizio precedente, se superiore; mentre per la seconda fascia il massimo edittale è di 20 milioni di euro, o per le imprese, fino al 4 % del fatturato mondiale totale annuo dell'esercizio precedente, se superiore.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- L. Bolognini, E. Pelino e C. Bistolfi, *Il regolamento privacy europeo*, Giuffrè, Milano, 2016;
- M. Colombo, *Regolamento Privacy UE 2016/679: Principi generali e Ruolo del Data Protection Officer,* Amazon, Versione Kindle, 2016.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).